VIVIER IA — FICHE RÉCAPITULATIVE

Module 6 — Cybersécurité IA en 5 points

À imprimer, garder près du clavier. Chaque point renvoie au module interactif.

SECTION 01 — Comptes, rôles et élévation de privilèges

À retenir : Compte : qui. Rôle : ce qu'il peut faire. Privilège : un droit précis.

Tous les accès en app_metadata, jamais en user_metadata | La clé de service uniquement côté serveur | Chaque rôle documenté (qui, quoi, pourquoi)

Compte : Qui est la personne (identité); Rôle : Ce que la personne peut faire (ensemble de droits)

SECTION 02 — RLS et tests avec de vrais rôles

À retenir : Une règle est correcte quand un test avec chaque rôle le prouve.

Un rôle de test pour chaque profil (visiteur, élèves, admin, serveur) | Chaque règle testée avec de vrais appels | Les lignes touchées comptées à chaq

RLS : Row Level Security : les règles ligne par ligne; Rôle de test : Un compte créé uniquement pour éprouver les règles

SECTION 03 — Donner le minimum : colonnes, tables, droits

À retenir : Donner le minimum de lignes ne suffit pas : donnez aussi le minimum de colonnes.

Les colonnes exposées listées par rôle | security_invoker sur chaque vue | Les données vraiment sensibles dans une table séparée

Politique colonnes : Ce qu'on voit, colonne par colonne; security_invoker : L'option qui applique les droits du lecteur, pas du créateur

SECTION 04 — Fichiers privés et liens temporaires

À retenir : Un document personnel va dans un dossier privé. Le public est réservé à ce que tout le monde peut voir.

with check sur chaque politique de bucket | Chaque document classé : public ou personnel | Les liens temporaires à durée courte, créés côté serveur

Bucket : Un espace de stockage de fichiers, public ou privé; with check : La règle qui contrôle où un fichier peut atterrir

SECTION 05 — Paiements : ne jamais croire le navigateur

À retenir : Le prix et le produit se lisent côté serveur, jamais dans le navigateur.

La confirmation par Pulse à signature vérifiée ou lecture API | Le prix lu côté serveur uniquement | Les 4 vérifications (statut, produit, lien, propriétaire

Webhook signé : La notification de paiement accompagnée d'une preuve cryptographique; Pulse : L'événement Chariow envoyé à votre serveur

SECTION 06 — Protéger le dernier administrateur et journaliser

À retenir : Ce qui doit toujours être vrai se vérifie dans la base, pas seulement dans l'écran.

Deux administrateurs minimum, deux personnes distinctes | Le journal écrit par la base (append-only) | Aucun secret dans les journaux, vérifié régulie

Bus factor : Le risque lié à la disparition d'une personne clé; Journal append-only : Des traces qu'on ajoute mais ne modifie ni n'efface